

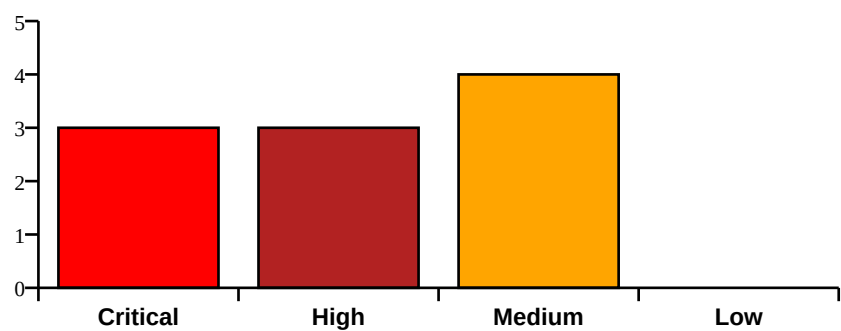
Vulnerability Scan Report

Target URL: http://localhost:3000
Generated (UTC): 2026-04-26 07:47:33Z

Summary

Metric	Count
Total Vulnerabilities	10
Critical Severity	3
High Severity	3
Medium Severity	4
Low Severity	0

Severity Distribution



Detailed Findings

1. Cryptographic Failure (High)

Location: http://localhost:3000

Evidence:

Application does not enforce HTTPS.

2. Cryptographic Failure (Medium)

Location: http://localhost:3000

Evidence:

Strict-Transport-Security header not set.

3. Identification & Authentication Failures (Medium)

Location: http://localhost:3000/#/login

Payload: token → Secure=False

Evidence:

Cookie transmitted without Secure flag.

4. Identification & Authentication Failures (Medium)

Location: http://localhost:3000/#/login

Payload: token → HttpOnly=False

Evidence:

Cookie accessible via JavaScript (XSS risk).

5. Identification & Authentication Failures (High)

Location: http://localhost:3000/#/login

Payload: exp field missing

Evidence:

JWT does not expire – can be reused indefinitely.

6. Identification & Authentication Failures (Critical)

Location: http://localhost:3000/#/login

Payload: data.password = 0192023a7bbd73250516f069df18b500

Evidence:

Sensitive data exposed inside JWT payload.

7. Identification & Authentication Failures (Critical)

Location: http://localhost:3000/#/login

Payload: data.deluxeToken =

Evidence:

Sensitive data exposed inside JWT payload.

8. Identification & Authentication Failures (Critical)

Location: http://localhost:3000/#/login

Payload: data.totpSecret =

Evidence:

Sensitive data exposed inside JWT payload.

9. Identification & Authentication Failures (Medium)

Location: http://localhost:3000/#/login

Payload: role = admin

Evidence:

User role exposed in JWT.

10. Identification & Authentication Failures (High)

Location: http://localhost:3000/#/login

Payload: Token stored in browser localStorage

Evidence:

Token accessible via JavaScript (XSS risk).

Activity Log

```
[07:46:59]
=====
[07:46:59] Starting Vulnerability Scan for http://localhost:3000
[07:46:59]
=====
[07:46:59] [*] Starting active crawl (mode=deep, headless=False)...
[07:47:00] [*] Attempting automatic login...
[07:47:00] [!] Active crawl error: You cannot call this from an async context - use a thread or sync_to_async.
[07:47:00] [*] Falling back to static crawl.
[07:47:00]
===== SCANNING http://localhost:3000 =====

[07:47:00] [INFO] Checking scheme → http
[07:47:00] [INFO] Initiating TLS handshake
[07:47:04] [SKIP] TLS check skipped → [WinError 10061] No connection could be made because the target machine
actively refused it
[07:47:04] [INFO] Checking cipher suite
[07:47:08] [SKIP] Cipher check skipped → [WinError 10061] No connection could be made because the target
machine actively refused it
[07:47:08] [INFO] Retrieving TLS certificate
[07:47:12] [SKIP] Certificate check skipped → [WinError 10061] No connection could be made because the target
machine actively refused it
[07:47:12] [HTTP] Checking HSTS header
[07:47:12] [HTTP] Response status → 200
[07:47:12] [HTTP] Response headers → {&#x27;Access-Control-Allow-Origin&#x27;: &#x27;*&#x27;;, &#x27;X-Content-
Type-Options&#x27;: &#x27;nosniff&#x27;;, &#x27;X-Frame-Options&#x27;: &#x27;SAMEORIGIN&#x27;;, &#x27;Feature-
Policy&#x27;: &#x27;"payment &#x27;self&#x27;";, &#x27;X-Recruiting&#x27;: &#x27;/#/jobs&#x27;;,
&#x27;Accept-Ranges&#x27;: &#x27;bytes&#x27;;, &#x27;Cache-Control&#x27;: &#x27;public, max-age=0&#x27;;,
&#x27;Last-Modified&#x27;: &#x27;Sun, 26 Apr 2026 05:45:49 GMT&#x27;;, &#x27;ETag&#x27;:
&#x27;W/&#x27;124fa-19dc8529929&#x27;;, &#x27;Content-Type&#x27;: &#x27;text/html; charset=UTF-8&#x27;;,
&#x27;Vary&#x27;: &#x27;Accept-Encoding&#x27;;, &#x27;Content-Encoding&#x27;: &#x27;gzip&#x27;;,
&#x27;Date&#x27;: &#x27;Sun, 26 Apr 2026 07:47:12 GMT&#x27;;, &#x27;Connection&#x27;: &#x27;keep-alive&#x27;;,
&#x27;Keep-Alive&#x27;: &#x27;timeout=5&#x27;;, &#x27;Transfer-Encoding&#x27;: &#x27;chunked&#x27;};
[07:47:12] [SCAN] Scanning 1 URL(s) for sensitive data exposure...
[07:47:12] [SCAN] Checking http://localhost:3000 for sensitive data...
[07:47:12]
===== REPORT =====
[07:47:12] - [High] HTTPS not enforced
[07:47:12] - [Medium] HSTS header missing
[07:47:12]
===== SCORE =====
[07:47:12] Crypto Risk Score → 50/100
[07:47:12] Risk Level → MEDIUM
[07:47:26] [+] Looking for login form...
[07:47:29] [+] Found login form at http://localhost:3000/#/login
[07:47:29] [+] Login form detected dynamically.
[07:47:29] [+] Logging in with provided credentials...
[07:47:31] [+] Analyzing cookies...
[07:47:31] [!] Missing Secure flag on token
[07:47:31] [!] Missing HttpOnly flag on token
[07:47:31] [+] Analyzing JWT token...
[07:47:31] [+] JWT token found.
[07:47:31] [JWT HEADER] {
  &quot;typ&quot;;: &quot;JWT&quot;;,
  &quot;alg&quot;;: &quot;RS256&quot;;
}
[07:47:31] [JWT PAYLOAD] {
  &quot;status&quot;;: &quot;success&quot;;,
  &quot;data&quot;;: {
    &quot;id&quot;;: 1,
    &quot;username&quot;;: &quot;;&quot;;,
    &quot;email&quot;;: &quot;admin@juice-sh.op&quot;;,
    &quot;password&quot;;: &quot;0192023a7bbd73250516f069df18b500&quot;;,
    &quot;role&quot;;: &quot;admin&quot;;,
    &quot;deluxeToken&quot;;: &quot;;&quot;;,
    &quot;lastLoginIp&quot;;: &quot;;&quot;;,
    &quot;profileImage&quot;;: &quot;assets/public/images/uploads/defaultAdmin.png&quot;;,
    &quot;totpSecret&quot;;: &quot;;&quot;;,
    &quot;isActive&quot;;: true,
    &quot;createdAt&quot;;: &quot;2026-04-26 05:45:44.729 +00:00&quot;;,
    &quot;updatedAt&quot;;: &quot;2026-04-26 05:45:44.729 +00:00&quot;;,
    &quot;deletedAt&quot;;: null
  },
  &quot;iat&quot;;: 1777189650
}
[07:47:33]
[*] Generating PDF report...
```